Compliance Annotation

BrightPath Learning Platform B.V.

Framework: GDPR + SOC 2 | Compliance Level: Significant Non-Compliance / High Risk

---

Finding 1: [VIOLATION] GDPR: Complete Absence of Legal Bases (Art. 6(1))

The policy lists multiple processing purposes (AI recommendations, analytics, quality assurance) but fails to identify the specific legal basis (e.g., Contract, Consent, Legitimate Interest) for any of them. This is a foundational breach of the GDPR lawfulness principle.

References: GDPR Art. 5(1)(a), Art. 6(1), Art. 13(1)(c)

Finding 2: [VIOLATION] GDPR: Mandatory DPO Appointment (Art. 37(1)(b))

BrightPath processes data for 500,000 active learners, including "learning activity," "session recordings," and "performance data." This constitutes large-scale monitoring of data subjects' behavior and performance. The failure to appoint a Data Protection Officer (DPO) is a direct violation of Art. 37.

References: GDPR Art. 37(1)(b), WP243 Guidelines

Finding 3: [VIOLATION] GDPR: High-Risk AI Profiling & Performance Monitoring (Art. 22)

The use of an "AI recommendation engine" that ingests "employee performance review scores" and "skills gap analysis" to "predict" development needs constitutes automated profiling. There is no evidence of a Data Protection Impact Assessment (DPIA) or the provision of Art. 22 safeguards (right to human intervention, right to contest).

References: GDPR Art. 4(4), Art. 22, Art. 35(3)(a)

Finding 4: [VIOLATION] GDPR: Joint Controllership Transparency (Art. 26)

The policy explicitly claims BrightPath and its customers are "joint controllers." However, it fails to provide the "essence of the arrangement"—a summary of the specific roles and responsibilities of each controller regarding the exercise of data subject rights and transparency duties.

References: GDPR Art. 26(1-2)

Finding 5: [VIOLATION] GDPR: Unprotected International Transfers to India (Art. 44-46)

Sensitive learner datasets are shared with DataMind Labs in Bangalore, India, for AI model training. India is not a country with an adequacy decision. While SCCs are mentioned, there is no evidence of a Transfer Impact Assessment (TIA) or supplementary technical measures (e.g., encryption where the key is held in the EU) to protect against local surveillance laws.

References: GDPR Art. 44, Art. 46, CJEU Schrems II

Finding 6: [VIOLATION] GDPR: Obstructive Data Subject Rights Modalities (Art. 12)

Directing users to contact their employer's HR department as the primary means of exercising rights creates an undue burden and a barrier to direct access. As a controller (or joint controller), BrightPath must facilitate the exercise of rights directly upon request.

References: GDPR Art. 12(2), Art. 15-21

Finding 7: [VIOLATION] GDPR: Failure to Define Retention Criteria (Art. 13(2)(a))

Stating that schedules are "being developed" confirms current non-compliance with the storage limitation principle. Data subjects must be informed of the specific retention periods or the objective criteria used to determine them at the time of collection.

References: GDPR Art. 5(1)(e), Art. 13(2)(a)

Finding 8: [VIOLATION] GDPR: Invalid Consent by "Continued Use" (Art. 4(11))

The statement that "Continued use... constitutes acceptance of changes" is a violation of the requirements for clear, affirmative consent. Policy changes, especially those impacting legal bases or processing purposes, cannot be accepted through passive user activity.

References: GDPR Art. 4(11), Art. 7, Recital 42

Finding 9: [VIOLATION] SOC 2: Governance and Security Leadership Gaps (CC1)

The lack of a dedicated CISO or a formal Security Steering Committee indicates a deficiency in security oversight. Relying solely on a CTO whose primary focus is typically product/delivery, without a dedicated security mandate or committee review, fails the COSO-aligned governance requirements of SOC 2.

References: SOC 2 CC1.2, CC1.3

Finding 10: [VIOLATION] SOC 2: Logical Access - Multi-Factor Authentication Gap (CC6)

BrightPath only enforces MFA for administrators. Failing to enforce MFA for the 500,000 regular learners accessing the platform—especially given the sensitivity of performance and recording data—violates the requirement to protect against unauthorized access via compromised credentials.

References: SOC 2 CC6.1

Finding 11: [VIOLATION] SOC 2: Incident Response Ineffectiveness (CC7)

The Incident Response Plan (IRP) exists only in "draft" form and lacks formal approval or tabletop testing. An unapproved, untested plan is considered operationally ineffective under the CC7 criteria for responding to and recovering from security incidents.

References: SOC 2 CC7.3, CC7.4

Finding 12: [VIOLATION] SOC 2: Business Continuity & DR Testing Failures (A1)

The Disaster Recovery (DR) plan has not been tested since March 2024. Furthermore, the RTO (12 hours) and RPO (24 hours) are high for an enterprise SaaS platform, and the failure to perform failover testing renders the availability claims unverifiable.

References: SOC 2 A1.2, A1.3

Finding 13: [VIOLATION] SOC 2: Lack of Vendor Due Diligence (CC9)

BrightPath admits to relying solely on "publicly available certifications" without conducting its own formal risk assessments or security questionnaires. This lack of active vendor oversight fails the "Management of Service Providers" trust criteria.

References: SOC 2 CC9.2

Finding 14: [VIOLATION] SOC 2: Absence of Security Log Aggregation (CC7)

Security-specific logs (authentication, data access) are not aggregated into a centralized monitoring tool or SIEM. Without centralized visibility and real-time alerting, the organization cannot effectively identify or respond to anomalous patterns or security breaches.

References: SOC 2 CC7.2

Finding 15: [VIOLATION] SOC 2: Excessive Off-boarding Latency (CC6)

An off-boarding window of 48-72 hours is significantly outside the industry standard for high-security environments, which typically requires access revocation within 24 hours or less to prevent "insider threat" or unauthorized access by terminated employees.

References: SOC 2 CC6.5